

Guía para PPTs — Team 4

Compliance Architecture Design · GDPR

Curso	SI805U — Integración de Sistemas
Docente	Mg. Jesús Huapaya Ciriaco
Ciclo	2026-2 · UNI
Dinámica	Week 2 — Dynamic 04 · Team 4
Regulación	GDPR (General Data Protection Regulation — UE)
Escenario	E-commerce EU ↔ CRM ↔ Marketing Analytics
Deliverable	Diagrama de arquitectura anotado con controles de compliance
Entrega	ahuapayac@uni.edu.pe · antes de las 12:00 PM

Asignación de temas

#	Integrante	Tema asignado	Ícono
1	Saul (tú)	Encryption	■
2	Siccha	Access Controls	■■
3	Christian Garcia	Audit Trails	■
4	~RonaldG	Segregation of Duties	■■
5	~Caceres	Data Residency Constraints	■

■■ **Regla clave:** los 5 controles se aplican **sobre el mismo diagrama**. Cada integrante superpone su control con un color/ícono distinto usando la leyenda de arriba.

Estructura general del deck

12 slides totales · 2 slides por tema

Slide	Contenido	Responsable
1	Portada — título, equipo, curso	Todos
2	Contexto GDPR + diagrama As-Is (sin controles)	Todos
3–4	■ Encryption (concepto + implementación)	Saul
5–6	■■ Access Controls (concepto + implementación)	Siccha
7–8	■ Audit Trails (concepto + implementación)	Christian
9–10	■■ Segregation of Duties (concepto + implementación)	RonaldG
11–12	■ Data Residency (concepto + implementación)	Caceres
13	Diagrama final To-Be con los 5 controles integrados	Todos

Plantilla estándar por tema (aplica a los 5)

Slide A — ¿Qué y por qué?	Slide B — ¿Cómo?
- Definición del control (1 línea) - Artículo GDPR que lo exige - Riesgo si no se implementa (multa real) - Ubicación en el diagrama (ícono/color)	- Implementación técnica concreta - Protocolo / herramienta / configuración - Evidencia de cumplimiento (log, cert) - Métrica o KPI de auditoría

Contexto GDPR — Escenario del deck

Escenario: Empresa de e-commerce en la UE que integra su plataforma web con un CRM (HubSpot/Salesforce) y una capa de Marketing Analytics (Google Analytics, Meta Ads). Los datos personales de clientes europeos fluyen entre estos 3 sistemas.

Dato regulado (PII): nombre, email, dirección, IP, cookies, historial de compras, comportamiento de navegación.

Multas de referencia: Meta €1.2B (2023, transferencias UE→USA); Amazon €746M (2021, cookies); British Airways €22M (2020, breach).

SLIDE A

¿Qué es Encryption y por qué GDPR la exige?

Definición	Convertir datos personales en texto ilegible mediante algoritmos criptográficos, tanto en tránsito como en reposo .
Base legal GDPR	Art. 32(1)(a) — 'seudonimización y cifrado de datos personales' como medida técnica apropiada. Art. 34(3)(a) — el cifrado exime de notificar breach a los titulares.
Riesgo si falta	British Airways (2020) : multa de £20M por breach donde datos de 400K clientes viajaban sin cifrar entre servicios.
Ubicación diagrama	■ sobre cada flecha (canales) y cada cilindro de BD (e-commerce DB, CRM DB, warehouse analytics).

SLIDE B

¿Cómo se implementa?

In-transit	TLS 1.3 obligatorio en todas las APIs REST (e-commerce ↔ CRM ↔ Analytics). Certificados con Let's Encrypt / DigiCert. HSTS habilitado.
At-rest	AES-256 en BD del e-commerce y CRM. Gestión de claves con AWS KMS o Azure Key Vault . Rotación cada 90 días.
Backups	Backups cifrados con claves distintas a las de producción. Almacenamiento en región UE (Frankfurt/Dublín).
Seudonimización	Emails y nombres reemplazados por tokens al enviarse a Analytics (cumple Art. 25 — 'Privacy by Design').
Evidencia	• Cert SSL Labs con nota A+ • Log de KMS con rotación de claves • Reporte trimestral de cifrado al DPO
KPI	100% de canales con TLS 1.3 · 0 BDs con PII sin cifrar

SLIDE A

¿Qué son Access Controls y por qué GDPR los exige?

Definición	Mecanismos que garantizan que solo personas autorizadas accedan a datos personales, aplicando el principio de mínimo privilegio .
Base legal GDPR	Art. 32(1)(b) — garantizar 'confidencialidad, integridad, disponibilidad'. Art. 5(1)(f) — principio de integridad y confidencialidad. Art. 25 — Privacy by Default (acceso restringido por defecto).
Riesgo si falta	Uber (2018) : multa de €400K por breach donde credenciales robadas de un empleado permitieron acceso a datos de 57M usuarios.
Ubicación diagrama	■ ■ sobre API Gateway + Identity Provider (IdP) que se ubica entre usuarios/sistemas y las 3 plataformas.

SLIDE B

¿Cómo se implementa?

RBAC	Roles definidos: Customer Service (lee pedidos), Marketing (datos agregados, no PII cruda), DPO (acceso total auditado), DevOps (infra sin PII).
MFA	Autenticación multifactor obligatoria para todos los accesos administrativos al CRM y a la BD del e-commerce.
IdP centralizado	Azure AD u Okta con SAML 2.0 / OIDC como Single Sign-On entre e-commerce, CRM y Analytics.
Consentimiento	Gestor de consentimiento del cliente (OneTrust, Cookiebot) integrado como 'access control' del propio dato — Art. 7 GDPR.
Sesión	Auto-logout a los 15 minutos de inactividad. Revisión trimestral de accesos (access recertification).
KPI	100% admins con MFA · 0 cuentas huérfanas · revisión de accesos cada 90 días

SLIDE A

¿Qué son Audit Trails y por qué GDPR los exige?

Definición	Registro inmutable de todas las acciones sobre datos personales: quién, qué, cuándo, desde dónde y con qué resultado .
Base legal GDPR	Art. 30 — Registro de actividades de tratamiento (obligatorio). Art. 33 — Notificación de breach en 72 horas (imposible sin logs). Art. 5(2) — principio de responsabilidad proactiva ('accountability').
Riesgo si falta	Marriott (2020) : multa de £18.4M — no detectaron un breach por 4 años por falta de monitoreo de accesos a la BD.
Ubicación diagrama	■ con flechas desde los 3 sistemas → SIEM central (recolector de logs con almacenamiento inmutable).

SLIDE B

¿Cómo se implementa?

SIEM	Splunk, Azure Sentinel o Wazuh como plataforma central de agregación de logs de las 3 plataformas.
Inmutabilidad	Logs en almacenamiento WORM (Write-Once-Read-Many): AWS S3 Object Lock o Azure Blob Immutable Storage.
Qué se registra	• Login/logout de cualquier sistema • Acceso, edición o descarga de PII • Cambios de permisos y roles • Ejercicio de derechos GDPR (acceso, rectificación, olvido)
Retención	Mínimo 1 año activo + 6 años archivado (recomendación EDPB para ejercer derechos y responder a la autoridad).
Alertas	Detección automática ante: descargas masivas, accesos fuera de horario, consultas a PII de VIPs, intentos fallidos consecutivos.
KPI	100% eventos capturados · alertas revisadas en <24h · reporte mensual al DPO

SLIDE A ¿Qué es SoD y por qué GDPR la exige?

Definición	Ninguna persona debe controlar todo el ciclo de un dato personal. Separar las funciones críticas entre distintos roles/personas.
Base legal GDPR	Art. 32(1)(b) y (d) — medidas organizativas para garantizar confidencialidad y evaluar regularmente su eficacia. Art. 24 — responsabilidad del responsable del tratamiento. Art. 25 — Privacy by Design (separación estructural de funciones).
Riesgo si falta	Morrisons (UK, 2014) : un solo empleado con acceso total exfiltró datos de 100K empleados . Litigio colectivo por años, precedente clave en Reino Unido.
Ubicación diagrama	■■ como capa de gobernanza horizontal sobre el RBAC — matriz de conflictos entre roles críticos.

SLIDE B ¿Cómo se implementa?

Matriz SoD	Regla base: quien crea ≠ quien aprueba ≠ quien audita . Documentar conflictos y compensaciones.
Ejemplos	• DevOps que despliega ≠ DBA que accede a PII en producción • Marketing que define campaña ≠ quien exporta la lista de clientes • Sysadmin de infra ≠ DPO que audita cumplimiento GDPR
Herramientas	SailPoint , Azure AD PIM (Privileged Identity Management) o CyberArk para acceso just-in-time con aprobación de un tercero.
Break-glass	Procedimiento de acceso de emergencia auditado — se registra, se aprueba a posteriori y se revisa en el siguiente comité.
Attestation	Revisión trimestral de la matriz de conflictos de roles. Firma del DPO y del área de seguridad.
KPI	0 conflictos SoD sin compensar · 100% accesos privilegiados con aprobación de segundo par

SLIDE A

¿Qué es Data Residency y por qué GDPR la exige?

Definición	Los datos personales de ciudadanos UE deben permanecer o transferirse solo a jurisdicciones con protección adecuada según GDPR.
Base legal GDPR	Capítulo V (Arts. 44–50) — Transferencias internacionales. Art. 45 — Decisiones de adecuación (países aprobados por la UE). Art. 46 — Cláusulas Contractuales Tipo (SCC) si no hay adecuación. Schrems II (2020) — invalidó el Privacy Shield UE-USA.
Riesgo si falta	Meta / Facebook (2023) : multa de €1.200 millones (la mayor de la historia GDPR) por transferir datos UE→USA sin garantías adecuadas post-Schrems II.
Ubicación diagrama	■ como frontera geográfica alrededor de la infra UE + etiquetas en cada BD indicando la región de almacenamiento.

SLIDE B

¿Cómo se implementa?

Región cloud	Fijar región UE : AWS Frankfurt (eu-central-1) / Dublín (eu-west-1) o Azure West Europe / North Europe. Bloquear replicación fuera de la UE.
Data mapping	Inventario del flujo transfronterizo : qué dato sale del EEE, hacia dónde, con qué base legal y con qué garantías (Art. 30 GDPR).
Transferencias USA	Marketing Analytics (Google, Meta) requiere: • Adhesión al EU-U.S. Data Privacy Framework (2023), o • Standard Contractual Clauses + Transfer Impact Assessment (TIA)
Controles técnicos	Azure Policy / AWS SCP que bloquean el despliegue de recursos con PII en regiones no autorizadas. Etiquetado 'data-classification: eu-personal'.
Contratos	DPA (Data Processing Agreement) firmado con cada proveedor cloud (Art. 28 GDPR). Anexos con las SCC actualizadas de 2021.
KPI	0 datos UE fuera de regiones autorizadas · 100% proveedores con DPA firmado · TIA revisada anualmente

Tips de diseño y preparación

Últimos detalles antes de exponer

■ Diseño del PPT

- **Diagrama base único.** Todos parten del mismo flujo E-commerce ↔ CRM ↔ Analytics. Cada uno superpone SU control con un color/ícono distinto.
- **Leyenda de íconos consistente:** ■ encryption · ■■ access controls · ■ audit trails · ■■ SoD · ■ data residency.
- **Paleta GDPR:** azul UE (#003399) + amarillo estrellas (#FFCC00) + gris neutro. Da coherencia visual y refuerza el marco regulatorio.
- **1 slide = 1 idea.** Bullets cortos (máx. 6 por slide), diagrama grande, sin párrafos.
- **Cita el artículo** específico de GDPR (Art. 32, Art. 5, Cap. V...). Le da rigor y protege ante preguntas del profe.
- **Multa real por tema.** Cada slide A debe tener 1 caso: BA, Marriott, Meta, Morrisons, Uber. Le da peso al 'por qué'.

■ Preparación para las 3 preguntas del profe

Recuerden: el profe elige **1 alumno al azar** de la lista de participantes y le hace 3 preguntas. Cada uno debe dominar:

#	Qué preparar	Cómo
1	Su tema en profundidad	Dominar los 2 slides propios y saber citar el artículo GDPR
2	Cómo su control se conecta con los otros 4	Ej: encryption sin access controls es inútil; audit trails sin SoD se pueden borrar
3	Un caso/multa real de incumplimiento	Meta €1.2B, BA £20M, Marriott £18M, Morrisons, Uber
4	Rol del DPO en el escenario	El Data Protection Officer coordina los 5 controles y responde ante la autoridad
5	Diferencia GDPR vs HIPAA/SOX	GDPR aplica a cualquier dato personal de UE, no solo salud o financiero

■ Checklist de entrega

- PPT / Miro con **link público** (verificar que 'anyone with the link can view')
- Los **5 controles anotados** sobre el mismo diagrama
- Cada tema tiene **2 slides** según la plantilla A/B
- Cita del **artículo GDPR** específico en cada slide A
- **1 multa real** mencionada por tema
- Email a ahuapayac@uni.edu.pe con asunto '**Dynamic 04 - Group 4**'
- Lista de **los 5 integrantes** que participaron activamente
- Envío **antes de las 12:00 PM** (1 pt de puntualidad)

